

Security audit eindrapport

OpenMRS Attachments Module

Gegenereerd op 2026-06-18 21:09, Europe/Amsterdam

Bevat hoofdrapport en tekstbijlagen uit docs/auditrapport/security/.

Bijlagen in deze PDF:

- Bijlage A - Traceability matrix
- Bijlage B - CRA mapping
- Bijlage C - Risk assessment
- Bijlage D - Pentest review punch-list
- Bijlage E - False-positivebeleid en register
- Bijlage F - Gap-analyse

Eindrapport

docs/auditrapport/security/12-security-audit-eindrapport.md

Security audit eindrapport - Sprint 4

1. Executive summary

Dit eindrapport vat de security- en compliancebevindingen samen voor de OpenMRS Attachments Module. De module verwerkt medische bijlagen en patientmetadata. Daardoor ligt de belangrijkste security-impact bij vertrouwelijkheid, integriteit en traceerbaarheid van patientattachments.

De audit laat zien dat de grootste risico's zitten in:

- file access en path traversal;
- hardcoded secrets in broncode;
- uploadvalidatie en MIME-controle;
- download- en search-autorisatie;
- logging van patientgegevens;
- dependency- en supply-chainrisico's.

Tijdens het verbeteronderzoek zijn meerdere maatregelen aantoonbaar ingericht of aangescherpt:

- CodeQL, Snyk, Dependabot en SBOM-generatie;
- Maven Tests workflow met JaCoCo coverage artifacts;
- verwijdering van hardcoded AWS-achtige credentials uit de broncode;
- veilige upload allowlist en MIME-validatie;
- path traversal mitigaties en regressietests;
- veilige logging zonder onnodige patient-PII;
- bijgewerkt pentestdocument met 10 pentestcases;
- traceability naar NEN-7510:2024 controls.

De belangrijkste open punten zijn niet inhoudelijk genegeerd, maar expliciet vastgelegd: Tika-upgradepad, productie-runtimecontrole, OpenMRS Core exposure en het verplicht maken van Maven Tests als required check.

2. Scope en context

2.1 Systeem

De scope is de OpenMRS Attachments Module. Deze module beheert medische attachments via OpenMRS REST endpoints en complex obs storage.

Belangrijke onderdelen:

- REST upload, download, search en delete/purge;
- opslag en ophalen van attachmentbestanden;
- koppeling aan patient, visit en encounter;
- MIME-detectie via Apache Tika;
- logging rond attachmentacties;
- CI/CD en dependency scanning.

2.2 In scope

- Securityanalyse van de modulecode;
- NEN-7510:2024 mapping;
- risicoanalyse en backlog;
- SAST, SCA en SBOM;
- pentestaanpak en pentestresultaten;
- securitytests en CI-bewijs;
- advies en open punten.

2.3 Out of scope

- echte productiepatientdata;
- volledige OpenMRS Core audit;
- productie-infrastructuur buiten deze repository;
- owner-only GitHub settings die niet door het team aangepast kunnen worden;

- definitieve bevestiging van productie-runtime/Tomcatversie, omdat die informatie niet aantoonbaar in deze repository staat.

3. Auditmethodologie

De audit is uitgevoerd als combinatie van documentreview, code review, threat modeling, SCA/SBOM-triage, CI/CD-review, regressietests en pentestdocumentatie.

Gebruikte methoden:

Methode | Toepassing
Gap-analyse | Eerste beoordeling van security- en compliancegaten.
Asset- en risicocriteria | Bepalen welke data en processen het belangrijkst zijn.
STRIDE threat model | Dreigingen classificeren op spoofing, tampering, repudiation, information disclosure, denial of service en elevation of privilege.
Risk assessment | Kans x impact, gekoppeld aan BIV/CIA en NEN-7510.
Security backlog | Bevindingen vertalen naar geprioriteerde maatregelen.
SAST/SCA/SBOM | CodeQL, Snyk, Dependabot en CycloneDX gebruiken als scan- en bewijsbronnen.
Pentest | Gerichte white-box pentest op 10 kwetsbaarheidscases.
CI/CD-review | Controleren of checks, artifacts, branch rules en reviewbeleid aantoonbaar zijn.
Traceability matrix | Controls koppelen aan bewijsartefacten.

Belangrijke brondocumenten:

- 01-gap-analyse.md
- 02-pipeline-compliance.md
- 03-assets-risicocriteria.md
- 04-threat-model.md
- 05-security-backlog.md
- 06-sca-sbom-triage.md
- 07-risicomatrix-bow-tie.md
- 08-attack-surface-overview.md
- 09-logging-gap-analyse.md
- 10-coverage-quality-gate.md
- 11-traceability-matrix.md
- 14-pentest-review-punchlist.md
- risk-assessment-report.md
- docs/auditrapport/08-pentest.pdf

4. Risico-analyse en bevindingen

De risk assessment gebruikt kans x impact en koppelt bevindingen aan vertrouwelijkheid, integriteit en beschikbaarheid. Omdat de module medische attachments verwerkt, is de risicobereidheid laag voor onbevoegde toegang tot patientbestanden of patientmetadata.

Aanvullende finding - Hardcoded credentials in broncode

Onderdeel | Invulling
Risico | AWS-achtige access keys stonden hardcoded in `AttachmentsActivator.java`. Ook als het voorbeeldwaarden zijn, normaliseert dit onveilig secretgebruik en kan dit bij echte waarden leiden tot cloud- of storage-toegang.
Impact | Hoog voor vertrouwelijkheid en integriteit als echte secrets in broncode terechtkomen.
OWASP | A02 Cryptographic Failures, A05 Security Misconfiguration
NEN-7510 | A.8.5, A.8.25, A.8.28
Status | Gemitigeerd; hardcoded credentials verwijderd en zoekactie op key-patronen geeft geen matches.
Bewijs | `14-pentest-review-punchlist.md`; `bewijs/pentest/2-1-secrets-before-hardcoded.png`; `bewijs/pentest/2-1-secrets-after-code-removed.png`; `bewijs/pentest/README.md`; `api/src/main/java/org/openmrs/module/attachments/AttachmentsActivator.java`

Finding 1 - Path traversal / arbitrary file read

Onderdeel | Invulling
Risico | Een aanvaller kan proberen bestanden buiten de bedoelde attachment storage te lezen.
Impact | Hoog voor vertrouwelijkheid; mogelijk uitlekken van patientbestanden of serverconfiguratie.
OWASP | A01 Broken Access Control
NEN-7510 | A.8.3, A.8.28, A.8.29
Status | Gemitigeerd en getest voor de onderzochte codepaden.
Bewijs | `04-threat-model.md`; `05-security-backlog.md`; `risk-assessment-report.md`; `docs/auditrapport/08-pentest.pdf`; `bewijs/pentest/2-4-handler-path-traversal-after-code.png`; `bewijs/pentest/2-4-handler-path-traversal-retest-rejected.png`; `api/src/main/java/org/openmrs/module/attachments/obs/DefaultAttachmentHandler.java`

Finding 2 - Upload allowlist bypass en MIME mismatch

Onderdeel | Invulling
Risico | Een lege of te ruime allowlist kan ongewenste bestandstypen toelaten. MIME mismatch kan schadelijke content verhullen.
Impact | Hoog voor integriteit en beschikbaarheid; mogelijk opslag van ongewenste of gevaarlijke bestanden.

OWASP | A05 Security Misconfiguration, A08 Software and Data Integrity Failures

NEN-7510 | A.8.28, A.8.29

Status | Gemitigeerd met veilige default allowlist, extensiecontrole, MIME-controle en regressietests.

Bewijs | `05-security-backlog.md`; `06-sca-sbom-triage.md`; `risk-assessment-report.md`; `docs/auditrapport/08-pentest.pdf`; `bewijs/pentest/2-5-upload-allowlist-after-code.png`; `bewijs/pentest/2-5-upload-allowlist-mime-retest-rejected.png`; `omod/src/main/java/org/openmrs/module/attachments/rest/AttachmentResource.java`; `omod/src/test/java/org/openmrs/module/attachments/rest/AttachmentResourceTest.java`

Finding 3 - Download-autorisatie / IDOR

Onderdeel | Invulling

Risico | Een gebruiker kan proberen attachment bytes op te halen via een bekende obs/attachment UUID.

Impact | Hoog voor vertrouwelijkheid, omdat attachments medische gegevens kunnen bevatten.

OWASP | A01 Broken Access Control

NEN-7510 | A.8.3, A.8.5, A.8.29

Status | Gedeeltelijk gemitigeerd met expliciete privilegecheck en regressietests; patient access blijft afhankelijk van OpenMRS autorisatiemodel.

Bewijs | `08-attack-surface-overview.md`; `risk-assessment-report.md`; `docs/auditrapport/08-pentest.pdf`; `bewijs/pentest/2-7-download-idor-after-privilege-check.png`; `bewijs/pentest/2-7-download-idor-retest-forbidden-tests.png`; `bewijs/pentest/2-7-download-idor-retest-green-output.png`; `omod/src/main/java/org/openmrs/module/attachments/rest/AttachmentBytesResource.java`; `omod/src/test/java/org/openmrs/module/attachments/rest/AttachmentBytesResourceTest.java`

Finding 4 - PII en log injection in logging

Onderdeel | Invulling

Risico | Logs kunnen patientnaam, geboortedatum, identifiers of vervalste logregels bevatten.

Impact | Middel tot hoog voor vertrouwelijkheid en traceerbaarheid.

OWASP | A09 Security Logging and Monitoring Failures

NEN-7510 | A.8.15, A.8.28

Status | Gemitigeerd voor onderzochte logpaden met veilige logmessage-methodes en tests.

Bewijs | `09-logging-gap-analyse.md`; `risk-assessment-report.md`; `docs/auditrapport/08-pentest.pdf`; `omod/src/test/java/org/openmrs/module/attachments/rest/AttachmentResourceTest.java`; `omod/src/test/java/org/openmrs/module/attachments/rest/AttachmentBytesResourceTest.java`

Finding 5 - Dependencyrisico Apache Tika en OpenMRS Core alerts

Onderdeel | Invulling

Risico | Kwetsbare dependencies kunnen via upload/parsing of runtimecomponenten misbruikt worden.

Impact | Hoog als kwetsbare code runtime bereikbaar is.

OWASP | A06 Vulnerable and Outdated Components

NEN-7510 | A.8.8, A.8.25, A.8.28

Status | Getriageerd; Tika oplossen zodra upgradepad mogelijk is; OpenMRS Core alerts open houden tot runtime/exposure bevestigd is.

Bewijs | `06-sca-sbom-triage.md`; `bewijs/sbom-sca/sbom.cdx.json`; `bewijs/sbom-sca/dependabot-tika-critical-alert-full.png`; `bewijs/sbom-sca/dependabot-openmrs-module-upload-zip-slip-overview.png`; `bewijs/sbom-sca/dependabot-openmrs-module-resources-path-traversal-overview.png`

5. SBOM en supply chain security

De supply-chaininrichting bestaat uit:

- Dependabot voor Maven dependency alerts en update PR's;
- Snyk voor SCA/SAST workflow en JSON artifacts;
- CycloneDX SBOM-generatie;
- CodeQL/code scanning;
- branch protection en PR-reviewplicht.

Het SBOM-bewijs staat in:

- docs/auditrapport/security/bewijs/sbom-sca/sbom.cdx.json
- docs/auditrapport/security/bewijs/sbom-sca/sbom-workflow-run-artifact.png
- docs/auditrapport/security/bewijs/sbom-sca/sbom-artifact-upload-log.png

De CycloneDX SBOM bevat 130 componenten voor org.openmrs.module:attachments:3.5.0. De belangrijkste dependencybevindingen zijn uitgewerkt in 06-sca-sbom-triage.md.

Besluiten:

Finding | Besluit | Reden

Apache Tika XXE | Oplossen | Tika wordt direct gebruikt bij upload MIME-detectie. Directe upgrade naar 3.2.2 blokkeert op Java 8.

OpenMRS Module Upload Zip Slip | Open houden | Runtime/exposure moet door owner of deploymentbeheerder worden bevestigd.

OpenMRS ModuleResourcesServlet path traversal | Open houden | Tomcatversie en module resource exposure zijn niet aantoonbaar in deze repository.

6. CRA-mapping op hoofdlijnen

De Cyber Resilience Act vraagt dat softwareleveranciers kwetsbaarheden beheersen, security by design toepassen en security-informatie aantoonbaar kunnen leveren. Voor dit project is CRA niet juridisch volledig uitgewerkt, maar de audit artefacten ondersteunen dezelfde doelen. De detailmapping staat in 13-cra-mapping.md.

CRA-thema | Projectmaatregel | Bewijs
Vulnerability handling | Dependabot, Snyk, CodeQL, SBOM en dependencytrriage. | `06-sca-sbom-triage.md`; `false-positive-beleid.md`; `sbom.cdx.json`
Secure by design | Threat model, secure coding fixes, uploadvalidatie en path traversal mitigaties. | `04-threat-model.md`; `05-security-backlog.md`; `risk-assessment-report.md`
Security testing | Pentest, regressietests, Maven Tests workflow en coverage artifacts. | `08-pentest.pdf`; `10-coverage-quality-gate.md`; `maven-tests.yml`
Traceerbaarheid | Traceability matrix, PR-reviewbeleid en bewijsmap. | `11-traceability-matrix.md`; `02-pipeline-compliance.md`; `bewijs/`

7. Conclusie en advies

De module heeft een duidelijke securityverbetering doorgemaakt. De belangrijkste technische risico's zijn zichtbaar gemaakt, geprioriteerd en voor meerdere kritieke codepaden gemitigeerd of getest. De auditdocumentatie bevat nu een samenhangende lijn van risico naar maatregel naar bewijs.

Advies:

1. Maak Maven Tests verplicht in de GitHub ruleset zodra een owner dit kan instellen.
2. Rond het Tika-upgradepad af via Java/OpenMRS upgrade of een veilige Java 8-compatibele oplossing.
3. Laat een owner de echte productie-runtime, Tomcatversie en module endpoint exposure bevestigen.
4. Houd Snyk, CodeQL, Dependabot en SBOM periodiek actief en bewaar relevante artifacts bij releases.
5. Herhaal pentestcases bij grote wijzigingen in upload, download, search, logging of dependencies.
6. Houd false-positive-beleid.md actueel bij nieuwe scanbevindingen.

8. Bijlagen

Bijlage | Locatie
Traceability matrix | `11-traceability-matrix.md`
SBOM | `bewijs/sbom-sca/sbom.cdx.json`
SAST/SCA bewijs | `bewijs/scanning/`, `bewijs/sbom-sca/`
Risicomatrix en bow-tie | `07-risicomatrix-bow-tie.md`
Threat model | `04-threat-model.md`
Risk assessment | `risk-assessment-report.md`
Pentest | `docs/auditrapport/08-pentest.pdf`
Pipeline compliance | `02-pipeline-compliance.md`
Coverage quality gate | `10-coverage-quality-gate.md`
False-positivebeleid en register | `false-positive-beleid.md`
CRA-mapping | `13-cra-mapping.md`

9. Niet afgeronde items

Item | Waarom niet afgerond | Vervolg
Maven Tests als required check | Vereist repository-owner rechten. | Owner moet de check selecteren in branch/ruleset settings.
Tika definitieve upgrade | Tika 3.2.2 vereist Java 11; project draait op Java 8. | Upgradepad onderzoeken of Java 8-compatibele oplossing kiezen.
OpenMRS Core runtime/exposure | Productie-runtime staat niet aantoonbaar in deze repository. | Owner/deploymentbeheerder moet runtime en endpointbereikbaarheid bevestigen.
Productie-infrastructuur audit | Buiten repositoryscope. | Apart behandelen met toegang tot deploymentomgeving.

Bijlage A - Traceability matrix

docs/auditrapport/security/11-traceability-matrix.md

Traceability matrix - Sprint 4

1. Doel

Deze traceability matrix koppelt de belangrijkste NEN-7510:2024 controls aan concrete maatregelen en bewijsartefacten in de repository. Hiermee is per control zichtbaar welk risico wordt afgedekt, waar de maatregel staat beschreven en welk bewijs gebruikt kan worden bij de audit.

Sprint 4 vraagt dat elk bewijsstuk traceerbaar is. Daarom verwijst deze matrix naar bestanden in docs/auditrapport/security/, codebestanden, workflows en bewijsafbeeldingen.

2. Scope

In scope:

- OpenMRS Attachments module;
- upload, download, search, delete/purge en file storage;
- CI/CD, branch protection, code scanning, SBOM/SCA en securitytests;
- logging en auditbaarheid rond patientattachments.

Out of scope:

- productie-infrastructuur buiten deze repository;
- echte productiepatientdata;
- instellingen waarvoor repository-owner rechten nodig zijn, zoals het selecteren van nieuwe required checks in GitHub.

3. Matrix

NEN-7510:2024 control | Securitydoel | Risico / finding | Maatregel | Bewijsartefacten | Status

A.8.3 Toegangsbeveiliging | Alleen bevoegde gebruikers mogen patientattachments lezen of wijzigen. | Path traversal, IDOR, verkeerde patientcontext en ongeautoriseerde metadata-inzage. | Raw path download is verwijderd/gevalideerd; download gebruikt attachment UUID; uploadcontext wordt gevalideerd; download heeft expliciete privilegecheck. | '04-threat-model.md'; '05-security-backlog.md'; '08-attack-surface-overview.md'; 'risk-assessment-report.md'; 'docs/auditrapport/08-pentest.pdf';

'omod/src/main/java/org/openmrs/module/attachments/rest/AttachmentBytesResource.java';
'omod/src/main/java/org/openmrs/module/attachments/rest/AttachmentResource.java' | Gedeeltelijk afgerond; productie- en patienttoegang blijven afhankelijk van OpenMRS runtimebeleid.

A.8.5 Authenticatie en autorisatie | Accounts, rechten, approvals en secrets moeten aantoonbaar veilig worden beheerd. | Ongeautoriseerde repositorywijzigingen, te brede toegang tot patientdata of hardcoded credentials. | MFA-bewijs, branch ruleset, production environment rules en PR-reviewplicht zijn vastgelegd. Hardcoded AWS-achtige credentials zijn verwijderd en via pentestbewijs hertest. | '02-pipeline-compliance.md'; 'bewijs/repository-access/mfa-aliriza-sari.png'; 'bewijs/repository-access/mfa-damian-buskens.png'; 'bewijs/repository-access/mfa-mohammed-ouaal.png'; 'bewijs/repository-access/main-branch-ruleset.png'; 'bewijs/repository-access/production-environment-rules.png'; 'bewijs/repository-access/dependabot-prs-review-required.png'; 'bewijs/pentest/2-1-secrets-before-hardcoded.png'; 'bewijs/pentest/2-1-secrets-after-code-removed.png'; 'bewijs/pentest/README.md' | Aanwezig.

A.8.8 Kwetsbaarheidsbeheer | Bekende kwetsbaarheden moeten worden gevonden, beoordeeld en opgevolgd. | Kwetsbare dependencies zoals Apache Tika en OpenMRS Core alerts. | Dependabot, Snyk en SBOM zijn ingericht; high/critical findings zijn getriageerd met besluit: oplossen, open houden of opvolgen. | '06-sca-sbom-triage.md'; 'false-positive-beleid.md'; 'bewijs/sbom-sca/dependabot-alerts-overview.png'; 'bewijs/sbom-sca/dependabot-tika-critical-alert-full.png'; 'bewijs/sbom-sca/dependabot-tika-critical-alert-details.png'; 'bewijs/sbom-sca/snyk-workflow-run-artifact-success.png'; 'bewijs/sbom-sca/sbom.cdx.json' | Aanwezig; Tika upgradepad en runtimecontrole blijven open.

A.8.15 Logging | Security events moeten bruikbaar zijn zonder onnodige patientdata te loggen. | Patientnaam, geboortedatum of identifiers kunnen in logs terechtkomen; log injection kan auditsporen vervalsen. | Logberichten zijn beperkt tot technische context; upload, download, delete/purge en concept-search logging zijn getest op dataminimalisatie. | '09-logging-gap-analyse.md'; 'risk-assessment-report.md';

'docs/auditrapport/08-pentest.pdf'; 'omod/src/test/java/org/openmrs/module/attachments/rest/AttachmentResourceTest.java';

'omod/src/test/java/org/openmrs/module/attachments/rest/AttachmentBytesResourceTest.java';

'omod/src/test/java/org/openmrs/module/attachments/rest/ObsByConceptListSearchHandlerTest.java' | Aanwezig voor de onderzochte logpaden.

A.8.25 Secure SDLC | Security moet onderdeel zijn van ontwerp, build, review en release. | Kwetsbare code kan zonder review of securitytests naar main gaan. | Branch protection/ruleset, PR review, CodeQL, Snyk, SBOM en Maven Tests workflow zijn ingericht. | '02-pipeline-compliance.md'; '10-coverage-quality-gate.md'; '.github/workflows/codeql.yml'; '.github/workflows/snyk.yml'; '.github/workflows/sbom.yml'; '.github/workflows/maven-tests.yml'; 'bewijs/scanning/pr-security-checks-passed.png'; 'bewijs/scanning/maven-tests-coverage-artifacts-success.png' | Aanwezig; Maven Tests moet door een owner nog als required check worden geselecteerd.

A.8.28 Secure coding | Onveilige file access, uploadvalidatie en parsing moeten worden voorkomen. | Path traversal, upload allowlist bypass, MIME mismatch, malformed base64 en hardcoded secrets. | Path normalization/root-checks, veilige default allowlist, extensie/MIME-validatie en robuuste base64validatie zijn toegevoegd en getest. Hardcoded credentials zijn verwijderd. | '04-threat-model.md'; '05-security-backlog.md'; 'risk-assessment-report.md'; 'docs/auditrapport/08-pentest.pdf'; 'api/src/main/java/org/openmrs/module/attachments/obs/DefaultAttachmentHandler.java';

'api/src/main/java/org/openmrs/module/attachments/AttachmentsActivator.java';

'omod/src/main/java/org/openmrs/module/attachments/rest/AttachmentResource.java';

'omod/src/test/java/org/openmrs/module/attachments/rest/AttachmentResourceTest.java';

'omod/src/test/java/org/openmrs/module/attachments/rest/AttachmentRestControllerTest.java'; 'bewijs/pentest/README.md' | Aanwezig voor de belangrijkste onderzochte codepaden.

A.8.29 Security testing | Belangrijke security-eisen moeten aantoonbaar getest worden. | Security regressies kunnen terugkomen zonder

automatische testdekking of zonder pentest-hertestbewijs. | Security regressietests draaien in Maven workflow; JaCoCo artifacts worden opgeslagen; pentestdocument is bijgewerkt met 10 cases; P1-hertestbewijs staat in de bewijsmap. | `10-coverage-quality-gate.md`; `14-pentest-review-punchlist.md`; `docs/auditrapport/08-pentest.pdf`; `bewijs/pentest/README.md`; `bewijs/scanning/maven-tests-coverage-artifacts-success.png`; `bewijs/scanning/jacoco-api-coverage-overview.png`; `bewijs/scanning/jacoco-omod-security-coverage-overview.png`; `.github/workflows/maven-tests.yml` | Aanwezig; owneractie nodig om Maven Tests verplicht te maken voor merge.

A.8.33 Testdata | Tests mogen geen productiepatientdata gebruiken. | Testen met echte patientdata kan privacyrisico veroorzaken. | Testdatabeleid beschrijft gebruik van synthetische of bestaande OpenMRS testdata. | `03-testdatabeleid.md`; testklassen onder `omod/src/test/java/` en `api/src/test/java/` | Aanwezig op documentatieniveau.

4. Open punten

Open punt | Reden | Vervolgactie

Maven Tests als required check selecteren | Hiervoor zijn repository-owner rechten nodig. | Owner moet na een groene workflow-run de check toevoegen aan de branch/ruleset.

Productie-runtime en Tomcatversie bevestigen | Deze informatie staat niet aantoonbaar in deze repository. | Deploymentbeheerder/owner moet runtimeversies en endpoint-exposure bevestigen.

Apache Tika definitief upgraden | Tika 3.2.2 vereist Java 11, terwijl het project op Java 8 draait. | Java/OpenMRS upgradepad bepalen of veilige Java 8-compatibele oplossing vinden.

OpenMRS Core Dependabot alerts sluiten | Runtime-impact is nog niet volledig bewezen. | Open houden totdat runtime/exposure door owner is bevestigd.

5. Conclusie

De belangrijkste NEN-controls zijn traceerbaar naar concrete repositorybestanden, bewijsafbeeldingen, workflows, tests en het pentestdocument. De auditbasis is daarmee aanwezig. De resterende punten zijn vooral afhankelijk van repository-owner rechten of productie-runtimeinformatie buiten deze repository.

Bijlage B - CRA mapping

docs/auditrapport/security/13-cra-mapping.md

CRA-mapping - Sprint 4

1. Doel

Dit document koppelt de securitymaatregelen uit het verbeteronderzoek aan hoofdlijnen uit de Cyber Resilience Act (CRA). De CRA-mapping is bedoeld als aanvullende bijlage bij het security audit eindrapport.

Dit is geen volledige juridische CRA-conformiteitsverklaring. De mapping laat zien hoe de gekozen maatregelen bijdragen aan kwetsbaarheidsbeheer, secure development, security testing en traceerbare bewijsvoering.

2. Scope

In scope:

- OpenMRS Attachments Module;
- repositorymaatregelen voor security en compliance;
- SAST, SCA, SBOM, pentest en regressietests;
- auditbewijs in docs/auditrapport/security/.

Out of scope:

- formele productcertificering;
- volledige leverancier- of marktverantwoordelijkheid onder de CRA;
- productie-infrastructuur buiten deze repository.

3. Mapping

CRA-thema | Verwachting op hoofdlijn | Projectmaatregel | Bewijsartefacten | Status
Security by design | Securityrisico's moeten vroeg in ontwerp en ontwikkeling worden meegenomen. | Threat model, attack surface overview, risk assessment en security backlog zijn uitgewerkt. | `04-threat-model.md`; `05-security-backlog.md`; `08-attack-surface-overview.md`; `risk-assessment-report.md` | Aanwezig
Vulnerability handling | Bekende kwetsbaarheden moeten worden gevonden, beoordeeld en opgevolgd. | Dependabot, Snyk, CodeQL en SCA/SBOM-triage zijn ingericht. | `06-sca-sbom-triage.md`; `false-positive-beleid.md`; `bewijs/sbom-sca/dependabot-alerts-overview.png`; `bewijs/sbom-sca/snyk-workflow-run-artifact-success.png` | Aanwezig; enkele findings blijven open met onderbouwing
SBOM / component transparency | Componenten en dependencies moeten inzichtelijk zijn. | CycloneDX SBOM wordt gegenereerd en bewaard als JSON. | `bewijs/sbom-sca/sbom.cdx.json`; `bewijs/sbom-sca/sbom-workflow-run-artifact.png`; `.github/workflows/sbom.yml` | Aanwezig
Secure updates | Dependency-updates moeten beoordeeld en veilig gemerged worden. | Dependabot PR's zijn zichtbaar en vereisen review; branch/ruleset beschermt 'main'. | `bewijs/repository-access/dependabot-prs-review-required.png`; `bewijs/repository-access/main-branch-ruleset.png`; `.github/dependabot.yml` | Aanwezig
Secure coding | Bekende kwetsbaarheidspatronen moeten in code worden voorkomen. | Path traversal, upload allowlist/MIME, malformed base64, download privilegecheck en veilige logging zijn gemitigeerd of getest. | `05-security-backlog.md`; docs/auditrapport/08-pentest.pdf; `omod/src/test/java/`; `api/src/test/java/` | Aanwezig voor onderzochte codepaden
Security testing | Security-eisen moeten getest en reproduceerbaar zijn. | Maven Tests workflow draait security regressietests en uploadt JaCoCo artifacts; pentestdocument bevat 10 cases. | `.github/workflows/maven-tests.yml`; `10-coverage-quality-gate.md`; `bewijs/scanning/maven-tests-coverage-artifacts-success.png`; docs/auditrapport/08-pentest.pdf | Aanwezig; required check vereist owneractie
Logging en incidentonderzoek | Security events moeten traceerbaar zijn zonder onnodige gevoelige data. | Logging gap analyse en tests voor veilige logberichten zijn uitgewerkt. | `09-logging-gap-analyse.md`; AttachmentResourceTest.java; AttachmentBytesResourceTest.java; `ObsByConceptListSearchHandlerTest.java` | Aanwezig
Access control | Onbevoegde toegang tot data moet worden voorkomen. | Branch protection, MFA, production environment rules en codegerichte toegangstests zijn vastgelegd. | `02-pipeline-compliance.md`; `bewijs/repository-access/mfa-\*.png`; `bewijs/repository-access/production-environment-rules.png`; docs/auditrapport/08-pentest.pdf | Aanwezig
Evidence and traceability | Securitymaatregelen moeten aantoonbaar en traceerbaar zijn. | Sprint 4 traceability matrix koppelt controls aan bewijs. | `11-traceability-matrix.md`; `12-security-audit-eindrapport.md`; `bewijs/` | Aanwezig

4. Belangrijkste open punten

Open punt | CRA-relevantie | Vervolgactie
Apache Tika upgradepad | Kwetsbaarheidsbeheer en veilige componenten. | Java/OpenMRS upgradepad bepalen of een Java 8-compatibele veilige oplossing kiezen.
OpenMRS runtime/exposure | Runtimekwetsbaarheden kunnen alleen goed worden beoordeeld met productiecontext. | Owner/deploymentbeheerder moet runtimeversie, Tomcatversie en endpoint-exposure bevestigen.
Maven Tests required check | Securitytests moeten release/merge aantoonbaar blokkeren bij falen. | Repository-owner moet Maven Tests als required check selecteren.
False-positive register vullen | Scanbevindingen moeten aantoonbaar beoordeeld worden. | Bij nieuwe of bestaande scanbevindingen status, reden en bewijs toevoegen in `false-positive-beleid.md`.

5. Conclusie

De repository bevat de belangrijkste bouwstenen voor CRA-gerelateerde security evidence: SBOM, SCA/SAST, securitytests, pentest, risk assessment, traceability en reviewbeleid. De module kan nog niet als volledig CRA-afgerond worden beschouwd, omdat enkele punten afhankelijk zijn van upgradebesluiten, ownerrechten en productie-runtimeinformatie. Wel is duidelijk vastgelegd welke maatregelen aanwezig zijn en welke opvolging nog nodig is.

Bijlage C - Risk assessment

docs/auditrapport/security/risk-assessment-report.md

Risk assessment report - OpenMRS Attachments Module

1. Documentinformatie

Onderdeel | Invulling
Project | OpenMRS Attachments Module
Document | Risk assessment report
Datum | 16 juni 2026
Scope | Attachments module, REST endpoints, file storage, logging, CI/CD en dependencies
Methode | CIA/BIV, STRIDE, kans x impact en NEN-7510:2024-2 koppeling
Pentest | Apart document aanwezig: `docs/auditrapport/08-pentest.pdf`; bijgewerkt naar 10 pentestcases

2. Gebruikte bronnen

Dit rapport is gebaseerd op de documenten en bewijzen die al in het project aanwezig zijn:

Bron | Waarvoor gebruikt
`01-gap-analyse.md` | Eerste security gaps en codevoorbeelden
`02-pipeline-compliance.md` | CI/CD, GitHub securitymaatregelen en pipeline-status
`03-assets-risicocriteria.md` | Crown jewels, risicoscore en risicobereidheid
`03-testdatabeleid.md` | Testdata-afspraken
`04-threat-model.md` | STRIDE threat model en risicomatrix
`05-security-backlog.md` | Security backlog en mitigaties
`06-sca-sbom-triage.md` | Dependency- en SBOM-triage
`07-risicomatrix-bow-tie.md` | Risicomatrix en bow-tie voor applicatie- en CI/CD-risico's
`false-positive-beleid.md` | Werkwijze voor false positives
`bewijs/` | Security-bewijs voor repository access, scanning en SBOM/SCA
`docs/auditrapport/08-pentest.pdf` | Apart pentestdocument met 10 uitgewerkte pentestcases
`11-traceability-matrix.md` | Sprint 4 traceability matrix voor NEN-7510 controls en bewijs
`12-security-audit-eindrapport.md` | Sprint 4 security audit eindrapport
`docs/architecture/` | C4-diagrammen voor systeem-, container- en componentniveau

3. Managementsamenvatting

De OpenMRS Attachments Module verwerkt medische bijlagen en bijbehorende patientmetadata. Daardoor ligt de belangrijkste security-impact bij vertrouwelijkheid: onbevoegde toegang tot attachment-inhoud, bestandsnamen, patientgegevens of logs kan leiden tot een datalek.

De belangrijkste risico's zitten in file access, uploadvalidatie, download-autorisatie, logging en dependencybeheer. Een eerder CodeQL-risico rond een raw /download-path= downloadpad is in de huidige broncode niet meer teruggevonden en is gekoppeld aan commit e9e4aa0 fix CodeQL security alerts. De huidige validatie gebruikt alleen UUID-gebaseerde attachment bytes en expliciete privilegechecks.

De repository heeft al meerdere securitymaatregelen ingericht, zoals CodeQL/code scanning, Dependabot, SBOM-generatie, GitHub Environments, branch protection/rulesets, secret scanning en MFA-bewijs. Het pentestdocument is bijgewerkt naar 10 pentestcases. Voor de belangrijkste P1-pentestcases is before/after- en hertestbewijs toegevoegd in bewijs/pentest/. Tegelijk blijven er nog open acties over, vooral rond enkele P2-pentestbewijzen, false-positive registratie, dependencytriage, productie-runtimebevestiging en securitytests als verplichte quality gate.

4. Scope

In scope:

- uploaden van patient attachments;
- zoeken en ophalen van attachmentmetadata;
- downloaden van attachment bytes;
- REST API endpoints van de module;
- OpenMRS services die door de module worden gebruikt;
- attachment file storage;
- applicatielogs;
- CI/CD, SBOM, SCA, CodeQL en Dependabot op hoofdlijnen.

Out of scope:

- volledige OpenMRS Core implementatie;
- productie-infrastructuur buiten de repository;
- echte productiepatientdata;

- productie-infrastructuur en runtime-informatie die niet aantoonbaar in deze repository staat.

5. Assets en crown jewels

De belangrijkste te beschermen assets zijn:

Asset | Classificatie | Belangrijkste impact
Bijlage-inhoud, zoals documenten, scans en foto's | PHI | Vertrouwelijkheid
Base64-gecodeerde uploadinhoud | PHI | Vertrouwelijkheid
Bestandsnaam | PII/PHI | Vertrouwelijkheid
Bijlschrift of opmerking bij attachment | PHI | Vertrouwelijkheid
Patientnaam, geboortedatum en identifiers | PII | Vertrouwelijkheid
Patient UUID of interne patient-ID | PII | Vertrouwelijkheid
Encounter- en visit-koppeling | PHI | Vertrouwelijkheid en integriteit
Obs-datum/tijd | PHI metadata | Integriteit
MIME-type en content-family | PHI metadata | Vertrouwelijkheid
Provider-identiteit | PII | Vertrouwelijkheid
Audit- en wijzigingsmetadata | PII | Integriteit
Serverbestandsinhoud via onveilige file access | PHI/credentials | Vertrouwelijkheid

Omdat de module medische gegevens verwerkt, is de risicobereidheid laag. Onbevoegde blootstelling van attachment-inhoud, serverbestanden of patient-PII in logs wordt als onacceptabel risico behandeld.

6. Risicocriteria

De risicoscore wordt berekend met:

risicoscore = kans x impact

Beide assen gebruiken een schaal van 1 tot en met 5.

Scoreband | Betekenis | Actie
1-6 | Laag risico | Accepteren en monitoren
8-12 | Verhoogd risico | Mitigeren binnen afgesproken termijn
15-25 | Hoog/onacceptabel risico | Direct behandelen en escaleren

Voor patientdata geldt dat rode risico's niet onbehandeld mogen blijven. Oranje risico's kunnen tijdelijk bestaan als er een duidelijke backlogactie en opvolging is.

7. Risico-overzicht

ID	Risico	BIV-impact	Kans	Impact	Score	Status
T01 | Raw '/download-path=' kon willekeurig bestandspad lezen | Vertrouwelijkheid | 4 | 5 | 20 | Gemitigeerd en gevalideerd; raw path endpoint is niet meer aanwezig
T02 | Path traversal via 'DefaultAttachmentHandler.getAttachmentByPath' | Vertrouwelijkheid, integriteit | 4 | 4 | 16 | Gemitigeerd en getest
T03 | Upload allowlist is te ruim als configuratie leeg is | Integriteit, beschikbaarheid | 4 | 4 | 16 | Gemitigeerd en getest
T04 | Download-autorisatie moet expliciet bewezen worden | Vertrouwelijkheid | 3 | 5 | 15 | Gedeeltelijk gemitigeerd en getest met expliciete privilegecheck
T05 | Patientgegevens kunnen in logs terechtkomen | Vertrouwelijkheid, traceerbaarheid | 3 | 4 | 12 | Gemitigeerd en getest voor attachment-fetch, upload/delete, bytes-download en concept-search lookup logging
T06 | Malformed base64 upload kan onduidelijk foutgedrag geven | Beschikbaarheid, integriteit | 3 | 3 | 9 | Gemitigeerd en getest
T07 | Legacy dependencies kunnen bekende CVE's bevatten | Vertrouwelijkheid, integriteit, beschikbaarheid | 3 | 4 | 12 | Gedeeltelijk afgerond; SCA-besluiten staan, runtimecontrole blijft open
T08 | Deployment secrets en deployment workflow zijn nog niet volledig bewezen | Integriteit | 2 | 4 | 8 | Moet nog gedaan worden
T09 | Build/securitytests zijn nog niet volledig betrouwbaar als quality gate | Integriteit, traceerbaarheid | 3 | 3 | 9 | Maven Tests workflow en JaCoCo coverage artifacts zijn ingericht en bewezen; required-check selectie blijft open omdat dit repository-owner rechten vraagt. Harde coverage threshold wordt in Sprint 3 bewust niet afgedwongen; coverage wordt via 60% reviewnorm en PR-review beoordeeld
T10 | Attachmentmetadata kan verkeerd gekoppeld worden aan patient/context | Integriteit, vertrouwelijkheid | 2 | 4 | 8 | Gemitigeerd en getest voor upload patient/visit/encounter mismatch

8. Hoogste risico's

De hoogste risico's uit de bestaande analyse zijn:

Prioriteit | Risico | Reden
1 | File access en path traversal | Attachment file storage bevat medische bestanden. Onveilige paden kunnen leiden tot uitlekken of manipulatie.
2 | Uploadvalidatie | Uploads zijn een belangrijk aanvalsvlak. Een lege of te ruime allowlist kan ongewenste bestandstypen toelaten.
3 | Download-autorisatie | Bij patientattachments moet aantoonbaar zijn dat alleen bevoegde gebruikers bytes kunnen downloaden.
4 | PII in logs | Logs zijn vaak breder toegankelijk dan medische data en mogen geen onnodige patientgegevens bevatten.
5 | Dependency- en CI/CD-risico's | Kwetsbare dependencies of zwakke quality gates kunnen onveilige code laten doorstromen.

9. Bestaande beveiligingsmaatregelen

Maatregel | Bewijs | Status
GitHub Environments 'dev', 'test' en 'prod' | 'bewijs/repository-access/github-environments.png' | Aanwezig

Production protection rules | `bewijs/repository-access/production-environment-rules.png` | Aanwezig
Branch protection / ruleset | `bewijs/repository-access/main-branch-ruleset.png` | Aanwezig
MFA voor teamleden | `bewijs/repository-access/mfa\*.png` | Aanwezig
Dependabot | `github/dependabot.yml`, `bewijs/sbom-sca/dependabot-alerts-overview.png`, `bewijs/repository-access/dependabot-prs-review-required.png` | Aanwezig; alerts en update PR's worden zichtbaar gemaakt
CodeQL/code scanning | `bewijs/scanning/codeql-workflow.png`, `bewijs/scanning/code-scanning-alerts.png` | Aanwezig
Secret scanning | `bewijs/scanning/github-security-settings.png` | Aanwezig
SBOM-generatie | `github/workflows/sbom.yml`, `bewijs/sbom-sca/sbom-workflow-success.png`, `bewijs/sbom-sca/sbom-artifact-overview.png`, GitHub
Actions run `Generate SBOM #15` | Aanwezig; artifact succesvol geupload
Snyk SCA/SAST | `github/workflows/snyk.yml`, `bewijs/sbom-sca/snyk-workflow-run-artifact-success.png`, `bewijs/sbom-sca/snyk-artifact-upload-success.png` | Aanwezig; workflow draait en JSON-artifacts worden geupload
PR securitychecks en review | `bewijs/scanning/pr-security-checks-passed.png`, `bewijs/repository-access/main-branch-ruleset.png`,
`bewijs/repository-access/dependabot-prs-review-required.png` | Aanwezig; CodeQL, Snyk en code scanning zijn groen op een PR. Failed checks
blokkeren merge en PR's vereisen review volgens de ingestelde PR/ruleset-werkwijze
Testdatabeleid | `03-testdatabeleid.md` | Aanwezig

10. NEN-7510:2024-2 koppeling

Control | Relevantie in dit project | Gekoppelde risico's
A.8.3 Toegangsbeveiliging | Alleen bevoegde gebruikers mogen patientattachments lezen of wijzigen. | T01, T02, T04, T10
A.8.5 Authenticatie/autorisatie | Rechten en omgevingsbescherming moeten aantoonbaar zijn. | T04, T08
A.8.8 Kwetsbaarheidsbeheer | CVE's en dependencyrisico's moeten worden gevonden en opgevolgd. | T07
A.8.15 Logging | Logs moeten bruikbaar zijn zonder onnodige patientgegevens te bevatten. | T05
A.8.25 Secure SDLC | Security moet onderdeel zijn van branch, build, review en release. | T08, T09
A.8.28 Secure coding | File access, uploads en parsing moeten veilig zijn ontworpen. | T01, T02, T03, T06
A.8.29 Security testing | Belangrijke security-eisen moeten met tests worden bewezen. | T01, T02, T03, T04, T09
A.8.33 Testdata | Testdata mag geen productiepatientdata bevatten. | Testdata-afspraken en pentestvoorbereiding

11. Kwetsbaarheden, mitigaties en NEN-7510

Kwetsbaarheid | Risico | Mitigatie | NEN-7510:2024-2 | Bewijs/status
Raw `/download-path=` file read | Onbevoegd lezen van serverbestanden of patientbestanden | Endpoint verwijderen of alleen veilige UUID-download toestaan | A.8.3, A.8.28, A.8.29 | Gemitigeerd via commit `e9e4aa0`; gevalideerd met codezoekactie en UUID-only bytes endpoint
Path traversal in attachment handler | Bestand buiten attachment storage lezen of manipuleren | `Path.resolve().normalize()` gebruiken en controleren dat pad binnen attachment-root blijft | A.8.3, A.8.28, A.8.29 | Gemitigeerd met root-directory check en regressietests
Upload allowlist bypass | Ongewenste bestandstypen uploaden of MIME-controle omzeilen | Veilige default allowlist instellen en extensie/MIME altijd valideren | A.8.28, A.8.29 | Gemitigeerd met veilige default allowlist, verplichte extensie/MIME-validatie en regressietests
Download-autorisatie niet expliciet bewezen | Onbevoegde gebruiker kan mogelijk attachment bytes downloaden | Expliciete privilegecheck of integratietest toevoegen | A.8.3, A.8.5, A.8.29 | Gedeeltelijk gemitigeerd met expliciete `View Attachments` check en regressietests
PII in logs | Patientnaam, geboortedatum of identifiers kunnen breder zichtbaar worden | Dataminimalisatie toepassen en auditlogging scheiden van applicatielogs | A.8.15, A.8.28 | Gemitigeerd met minimale logtekst voor attachment-fetch, upload/delete, bytes-download en concept-search lookup plus regressietests
Malformed base64 upload | Onvoorspelbaar foutgedrag of denial of service | Aparte parser met duidelijke validatie en negatieve tests | A.8.28, A.8.29 | Gemitigeerd met data-URI/base64-validatie en regressietests
Apache Tika XXE | Malicious bestand kan mogelijk XXE-triggeren bij bestandsdetectie/parsing | Tika upgraden naar gepatchte versie en upload-aanvalsvector beperken met allowlist/MIME-controle | A.8.8, A.8.28, A.8.29 | Besluit: oplossen; directe upgrade naar 3.2.2 getest maar geblokkeerd door Java 8; compensating control toegevoegd
OpenMRS Core dependency alerts | Runtime kan kwetsbaar zijn voor path traversal of Zip Slip | Runtimeversie controleren, OpenMRS Core upgraden en endpoint-exposure beperken | A.8.8, A.8.25, A.8.29 | Besluit: open houden; runtime exposure nog controleren

12. Mitigatieplan

Backlog ID | Maatregel | Prioriteit | Status
SB-01 | Verwijder of beveilig raw `/download-path=` en gebruik veilige UUID-download | P0 | Gemitigeerd en gevalideerd
SB-02 | Maak file access in handlers veilig met path normalization en root-check | P0 | Gemitigeerd en getest
SB-03 | Stel veilige upload allowlist in en valideer extensie en MIME altijd | P1 | Gemitigeerd en getest
SB-04 | Bewijs download-autorisatie met tests of expliciete check | P1 | Gedeeltelijk gemitigeerd en getest voor authenticatie/privilege
SB-05 | Verwijder onnodige PII uit logs en voeg veilige auditlogging toe | P2 | Gemitigeerd en getest voor attachment-fetch, upload/delete, bytes-download en concept-search lookup logging
SB-06 | Maak base64 upload parsing robuust | P2 | Gemitigeerd en getest
SB-07 | Triager dependency- en SBOM-findings | P2 | Besluiten afgerond; uitvoering/open runtimeonderzoek moet nog gedaan worden
SB-08 | Maak securitytests en coverage betrouwbaar in CI | P2 | Maven test workflow en JaCoCo artifacts toegevoegd; coveragebaseline beoordeeld; Maven Tests nog als required check opnemen
SB-09 | Test en versterk metadata-/patientbinding bij upload | P2 | Gemitigeerd en getest
SB-10 | Richt deployment secrets later veilig in via GitHub Environments | P3 | Moet nog gedaan worden

12.1 Pentest hertestbewijs

Voor B3 is het hertestbewijs voor de belangrijkste P1-pentestcases aangevuld in bewijs/pentest/.

Pentestcase | Status | Bewijs
2.1 Hardcoded AWS secrets | Gemitigeerd; hardcoded credentials verwijderd en zoekactie is schoon | `bewijs/pentest/2-1-secrets-before-hardcoded.png`; `bewijs/pentest/2-1-secrets-after-code-removed.png`; `bewijs/pentest/README.md`
2.2 Raw `/download-path=` path traversal | Gemitigeerd; download gebruikt UUID-flow en autorisatietests | `bewijs/pentest/2-2-raw-path-after-uuid-download-code.png`; `bewijs/pentest/2-2-raw-path-retest-authz-tests.png`
2.4 `DefaultAttachmentHandler` path traversal | Gemitigeerd; traversal wordt geweigerd | `bewijs/pentest/2-4-handler-path-traversal-after-code.png`; `bewijs/pentest/2-4-handler-path-traversal-retest-rejected.png`
2.5 Upload allowlist/MIME | Gemitigeerd; extensie- en MIME-controle getest | `bewijs/pentest/2-5-upload-allowlist-after-code.png`;

`bewijs/pentest/2-5-upload-allowlist-mime-retest-rejected.png`
2.7 Download-autorisatie / IDOR | Gemiteerd voor authenticatie/privelege; OpenMRS patienttoegang blijft runtimebeleid |
`bewijs/pentest/2-7-download-idor-after-privilege-check.png`; `bewijs/pentest/2-7-download-idor-retest-forbidden-tests.png`;
`bewijs/pentest/2-7-download-idor-retest-green-output.png`

13. SCA/SBOM opvolging

De SCA/SBOM-opvolging staat uitgewerkt in 06-sca-sbom-triage.md. De huidige bekende open dependencyrisico's zijn:

ID | Finding | Package | Status
SCA-001 | Apache Tika XXE, CVE-2025-66516 | `org.apache.tika:tika-core` 2.9.2 | Besluit: oplossen; upgrade naar 3.2.2 getest maar geblokkeerd door Java 8/class file 52.0; upload allowlist/MIME als compensating control toegevoegd
SCA-002 | OpenMRS Module Upload Zip Slip, CVE-2026-40076 | `org.openmrs.web:openmrs-web` 2.2.0 | Besluit: open houden; repository-prodconfig zet `MODULE\_WEB\_ADMIN=false` en modules read-only; echte productie-runtime en endpoint-exposure nog door owner bevestigen
SCA-003 | OpenMRS ModuleResourcesServlet path traversal, CVE-2026-40075 | `org.openmrs.web:openmrs-web` 2.2.0 | Besluit: open houden; Tomcatversie en echte productie-exposure staan niet aantoonbaar in deze repository en moeten door owner worden bevestigd

SBOM-bewijs is aanwezig via bewijs/sbom-sca/sbom-workflow-run-artifact.png en bewijs/sbom-sca/sbom-artifact-upload-log.png, waarin te zien is dat het artifact succesvol is geupload. De uitgepakte CycloneDX JSON staat in bewijs/sbom-sca/sbom.cdx.json en bevat 130 componenten voor org.openmrs.module:attachments:3.5.0. Snyk-bewijs is aanwezig via bewijs/sbom-sca/snyk-workflow-run-artifact-success.png en bewijs/sbom-sca/snyk-artifact-upload-success.png, waarin te zien is dat de workflow succesvol draait en dat snyk-sca.json en snyk-code.json als artifact worden geupload.

14. Kostenraming

Deze raming is een eerste inschatting in uren. Voor een concreet budget is een indicatief uurtarief van EUR 60 per uur gebruikt. Dit is een interne schatting voor development, security review en documentatie.

Maatregel	Rollen	Inschatting	Budget
SB-01 valideren en documentatie bijwerken | Developer + reviewer | 2-4 uur | EUR 120-240
SB-02 path traversal fix in handlers + tests | Developer + reviewer | 6-8 uur | EUR 360-480
SB-03 upload allowlist + MIME-validatie + tests | Developer + reviewer | 5-7 uur | EUR 300-420
SB-04 download-autorisatie aantonen met tests | Developer + reviewer | 6-8 uur | EUR 360-480
SB-05 PII uit logs verwijderen + logreview | Developer + reviewer | 3-5 uur | EUR 180-300
SB-06 base64 parser + negatieve tests | Developer + reviewer | 5-7 uur | EUR 300-420
SB-07 SCA/SBOM dependencytrage | Security reviewer + developer | 4-8 uur | EUR 240-480
SB-08 securitytests opnemen in CI | Developer + reviewer | 6-10 uur | EUR 360-600
SB-09 metadata-/patientbinding tests | Developer + reviewer | 4-6 uur | EUR 240-360
SB-10 deployment secrets via environments | Developer + reviewer | 2-4 uur | EUR 120-240
Pentest hertestbewijs verwerken | Tester + reviewer | 3-6 uur | EUR 180-360

Totale eerste inschatting: 46-73 uur, oftewel EUR 2.760-4.380 bij EUR 60 per uur. Dit is exclusief extra tijd voor onverwachte dependency-upgrade problemen.

15. Security tests als quality gate

Securitytests zijn technisch ingericht als PR workflow. De Maven Tests workflow genereert ook JaCoCo coverage rapporten als artifacts. De eerste GitHub Actions run is groen en toont beide coverage artifacts. De JaCoCo HTML-overzichten zijn inhoudelijk beoordeeld: API line coverage is 74% en OMOD security line coverage is 66%. De Maven Tests check moet nog als verplichte required check in de ruleset worden geselecteerd door iemand met repository-owner rechten. Voor Sprint 3 is besloten om geen harde coverage threshold af te dwingen; coverage wordt beoordeeld via de 60% reviewnorm, artifactbewijs en PR-review.

Stap | Gewenste inrichting | Status
Maven testjob | Unit- en integratietests draaien bij pull requests | Ingericht en groen bewezen in `bewijs/scanning/maven-tests-coverage-artifacts-success.png`; required-check selectie volgt nog
Coverage rapport | JaCoCo rapporten worden gemaakt voor API en OMOD security tests | Ingericht en artifacts bewezen in `bewijs/scanning/maven-tests-coverage-artifacts-success.png`; baseline beoordeeld in `bewijs/scanning/jacoco-api-coverage-overview.png` en `bewijs/scanning/jacoco-omod-security-coverage-overview.png`; geen harde threshold in Sprint 3
Security regressietests | Tests voor path traversal, uploadvalidatie, autorisatie, patientbinding en base64 parsing | Aanwezig voor path traversal, uploadvalidatie/MIME, download-autorisatie, patient/visit/encounter mismatch en base64 parsing
SCA/SAST artifacts | Snyk SCA en Snyk Code resultaten bewaren als artifact | Aanwezig; artifact upload succesvol
PR securitychecks | CodeQL, Snyk en code scanning draaien op pull requests | Aanwezig; groen bewijs in `bewijs/scanning/pr-security-checks-passed.png`
SBOM artifact | CycloneDX SBOM genereren en bewaren | Aanwezig; artifact succesvol geupload in `Generate SBOM #15`; `sbom.cdx.json` staat in de bewijsmap
Required checks | Branch protection/ruleset verplicht de security/testchecks | Aanwezig voor bestaande PR-checks; nieuwe Maven testjob moet na eerste run nog als required check worden geselecteerd
Review policy | Pull requests naar `main` hebben minimaal 1 review nodig | Aanwezig; `bewijs/repository-access/dependabot-prs-review-required.png` toont dependency PR's met 'Review required'
Fail policy | Foutieve checks blokkeren merge; high/critical findings vragen expliciete triage | Aanwezig voor PR-checks; inhoudelijke triage staat in `06-sca-sbom-triage.md`

De huidige situatie bewijst dat securitychecks op PR-niveau draaien en groen kunnen afronden. Volgens de ingestelde PR/ruleset-werkwijze kunnen PR's met foutieve checks niet worden gemerged en is minimaal 1 review nodig.

16. Moet nog gedaan worden

De volgende onderdelen zijn nog niet volledig afgerond of vereisen externe rechten/informatie. Ze worden daarom als open punt vastgelegd:

Onderdeel | Actie

Pentest | `08-pentest.pdf` is bijgewerkt naar 10 pentestcases

Pentest-bewijs | P1-hertestbewijs is toegevoegd voor secrets, raw path download, handler path traversal, upload allowlist/MIME en download-autorisatie. Voor P2-cases zoals malformed base64, patientcontext, log injection en search metadata disclosure kan nog extra request/response- of testoutputbewijs worden toegevoegd

False-positive register | Registerdeel in `false-positive-beleid.md` aanvullen met beoordeelde scanbevindingen

Dependencytrriage | Besluiten zijn genomen; Tika oplossen met upgradepad en compensating control; OpenMRS alerts blijven open totdat productie-runtime, Tomcatversie en endpoint-exposure door owner zijn bevestigd

Securitytests en coverage | Path traversal, uploadvalidatie/MIME, download-autorisatie, patientbinding, base64 parsing en veilige logging zijn toegevoegd; Maven workflow met JaCoCo artifacts is ingericht en de baseline is beoordeeld; Maven Tests moet nog als required check worden geselecteerd

CI quality gate | PR-checks zijn groen bewezen en failed checks blokkeren merge; minimaal 1 review is verplicht

Sprint 4 auditrapportage | Traceability matrix en security audit eindrapport zijn toegevoegd in `11-traceability-matrix.md` en `12-security-audit-eindrapport.md`

17. Conclusie

De risk assessment laat zien dat de grootste risico's draaien om vertrouwelijkheid van patientattachments en patientmetadata. De basisdocumenten zijn aanwezig: assets, risicocriteria, threat model, pipeline-compliance, testdatabeleid en security backlog.

De huidige beveiligingsinrichting bevat al belangrijke maatregelen zoals CodeQL, Dependabot, SBOM, secret scanning, MFA, environments en branch protection. Sprint 4 voegt hier een traceability matrix en security audit eindrapport aan toe. De belangrijkste vervolgstap is het afronden van de open owner- en runtimeafhankelijke punten, zoals Maven Tests als required check, Tika-upgradepad en productie-runtimebevestiging.

Bijlage D - Pentest review punch-list

docs/auditrapport/security/14-pentest-review-punchlist.md

Pentest review punch-list - B1

1. Doel

Dit document is de human-review van docs/auditrapport/08-pentest.pdf voor criterium B1. Het doel is om exact vast te leggen wat nog ontbreekt voordat de pentest als volledig bewijs kan worden gebruikt voor de onderdelen Pentest en Mitigatie/validatie.

De review is uitgevoerd op basis van:

- docs/auditrapport/08-pentest.pdf
- docs/auditrapport/security/risk-assessment-report.md paragraaf 16
- bestaande bewijsbestanden in docs/auditrapport/security/bewijs/
- bestaande regressietests in api/src/test/java/ en omod/src/test/java/

2. Reviewconclusie

Controlepunt | Beoordeling | Toelichting

Richt het pentestplan zich op de hoogste risico's- | Ja | De pentest behandelt secrets, path traversal, uploadvalidatie, download-autorisatie, logging, base64 parsing, patient-context mismatch en search metadata disclosure. Dit sluit aan op het threat model en risk assessment.

Zijn de stappen reproduceerbaar- | Gedeeltelijk | Meerdere cases beschrijven teststappen, maar niet elke case bevat een concreet request, response, commando of testoutput.

Is de meest kritieke kwetsbaarheid aantoonbaar uitgebuit- | Gedeeltelijk | De path traversal en secrets cases zijn inhoudelijk beschreven, maar before-bewijs en after-hertestbewijs zijn niet volledig als artefact opgenomen.

Is er before/after re-test bewijs- | Onvoldoende | De PDF bevat oplossingen, maar geen complete hertestsectie per kritieke finding. Het woord hertest komt niet voor in de PDF.

Sluit dit aan op 'risk-assessment-report.md' paragraaf 16- | Ja | De risk assessment noemt expliciet dat hertestbewijs, screenshots en request/response of command output per kwetsbaarheid nog moeten worden toegevoegd waar dit ontbreekt.

3. Kritieke punch-list voor B3

Voor B3 moeten vooral de kritieke en hoge risico's worden aangevuld met aantoonbaar bewijs. Gebruik hiervoor bij voorkeur map:

docs/auditrapport/security/bewijs/pentest/

Gebruik bestandsnamen die het patroon volgen:

<case>-<finding>-<before|after|retest>-<korte-omschrijving>.png

Voorbeeld:

2-4-path-traversal-retest-rejected.png

4. Punch-list per pentestcase

Case | Risico | Huidige status in PDF | Exact ontbrekend bewijs | B3-actie | Prioriteit

2.1 Hardcoded AWS secrets | Secrets in broncode kunnen cloutoegang lekken. | Finding en oplossing zijn beschreven. | Before-screenshot van oude hardcoded secret of codezoekactie; after-screenshot dat secret uit code is verwijderd of naar '.env.template'/environment aanpak is verplaatst; re-test met secret search of secret scanning bewijs. | Voeg before/after/re-test bewijs toe en beschrijf dat nieuwe zoekactie geen hardcoded AWS secret meer vindt. | P1

2.2 Raw '/download-path=' path traversal | Arbitrary file read via user-controlled path. | Finding is beschreven als historische kritieke kwetsbaarheid. | Before-bewijs van oude endpoint/code of CodeQL finding; after-bewijs dat endpoint niet meer bestaat; re-test via codezoekactie of request die niet meer werkt. | Voeg bewijs toe dat '@RequestParam("path")', 'new File(path)' of raw path download niet meer in 'AttachmentBytesResource' aanwezig is. | P1

2.3 PII in applicatielogs | Patientdata kan via logs uitlekken. | Finding en oplossing zijn beschreven. | Before-screenshot/logvoorbeeld met patientnaam/geboortedatum/identificer; after-testoutput of screenshot van veilige logtest; re-test dat logs geen PII bevatten. | Voeg testoutput toe van 'AttachmentsServiceImplTest' of relevante logmessage-test en leg uit welke PII niet meer voorkomt. | P1

2.4 Path traversal in 'DefaultAttachmentHandler' | File read buiten attachment directory. | Finding, risico en oplossing zijn beschreven. | Concrete exploit/testpayload zoals '../secret.txt'; after bewijs dat traversal wordt geweigerd; testoutput van 'DefaultAttachmentHandlerTest'. | Voeg screenshot of testoutput toe van traversal test en re-test met geweigerde payload. | P1

2.5 Upload allowlist bypass | Ongewenste bestanden of MIME mismatch kunnen worden geupload. | Finding en oplossing zijn beschreven. | Before-bewijs dat lege allowlist controle oversloeg of codefragment; after-bewijs dat '.exe'/MIME mismatch wordt geweigerd; testoutput van uploadvalidatietests. | Voeg screenshot/testoutput toe van veilige default allowlist, '.exe' rejection en MIME mismatch rejection. | P1

2.6 Malformed base64 upload | Onvoorspelbare fouten of DoS bij foutieve base64. | Finding en oplossing zijn beschreven. | Requestvoorbeeld met ontbrekende comma, leeg content-type of niet-base64 payload; after-bewijs dat gecontroleerde fout ontstaat; testoutput van negatieve base64tests. | Voeg testoutput toe van 'base64MultipartFile_shouldReject...' tests en beschrijf de re-testresultaten. | P2

2.7 Download-autorisatie / IDOR | Onbevoegde gebruiker kan attachment bytes downloaden. | Teststappen en oplossing zijn beschreven. | Request/response of testoutput voor gebruiker zonder login/zonder 'View Attachments'; after-bewijs dat '401/403' of exception optreedt; bewijs van expliciete privilegecheck. | Voeg screenshot/testoutput toe van 'AttachmentBytesResourceTest' voor unauthenticated en missing privilege. | P1

2.8 Patient/visit/encounter mismatch | Attachment kan aan verkeerde patientcontext worden gekoppeld. | Finding en oplossing zijn beschreven. | Requestvoorbeeld met patient A + visit/encounter B; after-bewijs dat upload wordt geweigerd; testoutput van mismatchtests. | Voeg testoutput toe van `postAttachment\_shouldThrowWhenVisitAndEncounterDoNotMatch`, patient/visit mismatch en patient/encounter mismatch. | P2

2.9 Log injection en gevoelige data in upload/delete logs | Logs kunnen vervalst worden of PII bevatten. | Finding en oplossing zijn beschreven. | Payload met newline/fake logtekst; after-bewijs dat newline wordt gesanitized; testoutput voor upload/delete/download logmessage sanitization. | Voeg testoutput toe van logmessage-tests in `AttachmentResourceTest` en `AttachmentBytesResourceTest`. | P2

2.10 Search metadata disclosure | Gebruiker kan metadata van andere patient zien. | Finding en oplossing zijn beschreven. | Concreet search request met patient UUID; expected/actual response; after-bewijs of test die geen metadata lekt. | Voeg minimaal request/response of onderbouwde testnotitie toe. Als dit nog niet getest is, markeer als open vervolgactie. | P2

5. Minimale bewijsset voor B3

Om B3 af te ronden is minimaal deze bewijsset nodig:

Bewijs | Waarom nodig
Secrets before/after/re-test | B3 noemt expliciet re-test van P1 secrets fix als fresh mitigation evidence.
Path traversal before/after/re-test | Dit is de meest kritieke datalekcategory en moet aantoonbaar zijn gereduceerd.
Upload allowlist/MIME after-test | Bewijst dat de mitigatie technisch werkt.
Download IDOR after-test | Bewijst dat onbevoegde download wordt geweigerd.
Logging/PII after-test | Bewijst dat privacyrisico in logs is verlaagd.
Patient-context mismatch after-test | Bewijst dat medische attachments niet verkeerd gekoppeld worden.

6. Toegevoegd bewijs

De eerste P1-bewijsset is toegevoegd in:

docs/auditrapport/security/bewijs/pentest/

Case | Status | Bewijs
2.1 Hardcoded AWS secrets | Before/after toegevoegd; commandoretest is schoon | `bewijs/pentest/2-1-secrets-before-hardcoded.png`; `bewijs/pentest/2-1-secrets-after-code-removed.png`; `bewijs/pentest/README.md`
2.2 Raw `/download-path=` path traversal | After/re-test toegevoegd | `bewijs/pentest/2-2-raw-path-after-uuid-download-code.png`; `bewijs/pentest/2-2-raw-path-retest-authz-tests.png`
2.4 `DefaultAttachmentHandler` path traversal | After/re-test toegevoegd | `bewijs/pentest/2-4-handler-path-traversal-after-code.png`; `bewijs/pentest/2-4-handler-path-traversal-retest-rejected.png`
2.5 Upload allowlist/MIME | After/re-test toegevoegd | `bewijs/pentest/2-5-upload-allowlist-after-code.png`; `bewijs/pentest/2-5-upload-allowlist-mime-retest-rejected.png`
2.7 Download-autorisatie / IDOR | After/re-test toegevoegd | `bewijs/pentest/2-7-download-idor-after-privilege-check.png`; `bewijs/pentest/2-7-download-idor-retest-forbidden-tests.png`; `bewijs/pentest/2-7-download-idor-retest-green-output.png`

7. Nog ontbrekend bewijs

Case | Bestandsnaam
2.8 | `2-8-patient-context-mismatch-retest-rejected.png`
2.9 | `2-9-log-injection-retest-sanitized.png`
2.10 | `2-10-search-metadata-retest-no-disclosure.png`

Voor 2.3 PII in logs en 2.6 malformed base64 is nog apart testoutput- of request/responsebewijs nodig als deze cases volledig in de pentestbijlage moeten worden afgerond.

8. Klaar-definitie voor B3

B3 is klaar wanneer:

1. Elke P1-case een reproduceerbare exploit of duidelijke before-situatie heeft.
2. Elke P1-case een after/re-test heeft die laat zien dat het risico is verlaagd.
3. De pentest PDF of een pentest-bijlage verwijst naar de bewijsbestanden.
4. De mitigatie- en validatiesectie expliciet aangeeft welke risico's opgelost, beperkt of open zijn.
5. risk-assessment-report.md paragraaf 16 niet meer hoeft te melden dat hertestbewijs ontbreekt voor kritieke vulnerabilities.

9. Advies

De P1-cases hieronder hebben nu bewijs in de repository:

1. 2.1 Hardcoded AWS secrets
2. 2.2 Raw /download-path= path traversal
3. 2.4 DefaultAttachmentHandler path traversal
4. 2.5 Upload allowlist/MIME
5. 2.7 Download-autorisatie / IDOR

Daarna kunnen de P2-cases worden aangevuld met testoutput of als onderbouwde vervolgactie blijven staan.

Bijlage E - False-positivebeleid en register

docs/auditrapport/security/false-positive-beleid.md

False-positivebeleid en register

Doel

Dit document beschrijft hoe scanner-bevindingen (Snyk, CodeQL, Dependabot, SBOM/SCA) worden getriageerd, wanneer een bevinding als false positive wordt aangemerkt en waar dit wordt vastgelegd. Zo blijft controleerbaar waarom een melding niet is opgevolgd en wie daarvoor heeft getekend.

Triageproces

1. Elke nieuwe bevinding uit een scan wordt binnen vijf werkdagen beoordeeld door een teamlid.
2. De beoordelaar stelt vast of de bevinding terecht is (echte kwetsbaarheid), niet van toepassing (false positive) of geaccepteerd risico.
3. Terechte bevindingen worden opgelost of als issue op de security backlog gezet.
4. False positives en geaccepteerde risico's worden vastgelegd in het register (zie hieronder) en daarna pas onderdrukt in de tool.
5. Een tweede teamlid controleert de onderbouwing en tekent af. Niemand tekent zijn eigen triage af.

Wanneer is iets een false positive-

Een bevinding wordt alleen als false positive aangemerkt als aan minstens een van deze voorwaarden is voldaan:

- de gemelde kwetsbare code of dependency wordt aantoonbaar niet uitgevoerd (bijvoorbeeld alleen in testscope);
- de scanner interpreteert de code aantoonbaar verkeerd (bijvoorbeeld een gemelde injectie waar de invoer al gevalideerd wordt);
- de bevinding betreft een omgeving of configuratie die in dit project niet bestaat.

Twijfelgevallen zijn geen false positive: die blijven open of worden als geaccepteerd risico met motivatie vastgelegd. "Te veel werk om op te lossen" is nooit een geldige reden.

Statuswaarden

Status | Betekenis
Open | Finding is gezien, maar nog niet volledig onderzocht.
False positive | Finding is onderzocht en niet relevant of niet exploitable bevonden.
Geaccepteerd restrisco | Finding is echt, maar tijdelijk of bewust geaccepteerd met reden.
Opgelost | Finding is opgelost met codewijziging, configuratie of dependency-update.
Niet geaccepteerd | Finding is echt en moet nog worden opgelost.

Register

False positives en geaccepteerde risico's worden hieronder gelogd met per bevinding de tool, locatie, reden, bewijs en status.

ID	Datum	Tool	Finding	Locatie	Severity	Beoordeling	Reden	Bewijs	Status	Afgetekend door
CS-001	2026-06-16	CodeQL	Uncontrolled data used in path expression	`AttachmentBytesResource.java`	High	Echte finding	Raw `/download-path=` endpoint gebruikte user-controlled padinput. Endpoint is verwijderd in commit `e9e4aa0`. PR #21 / commit `e9e4aa0`; `bewijs/pentest/2-2-raw-path-after-uuid-download-code.png`; `bewijs/pentest/2-2-raw-path-retest-authz-tests.png`	Opgelost	Audit-aftekening	2026-06-18
CS-002	2026-06-16	CodeQL	Polynomial regular expression used on uncontrolled data	`ObsByConceptListSearchHandler.java`	High	Echte finding	Regexverwerking op user-controlled input is aangepast en er is testdekking toegevoegd in commit `e9e4aa0`. PR #21 / commit `e9e4aa0`	Opgelost	Audit-aftekening	2026-06-18
PT-001	2026-06-18	Pentest	Hardcoded AWS-like secrets	`AttachmentsActivator.java`	High	Echte finding	Hardcoded credential-achtige waarden stonden in broncode. De waarden werden nergens gebruikt en zijn verwijderd. Hertest met repositoryzoekactie geeft geen matches. `bewijs/pentest/2-1-secrets-before-hardcoded.png`; `bewijs/pentest/2-1-secrets-after-code-removed.png`; `bewijs/pentest/README.md`	Opgelost	Audit-aftekening	2026-06-18
SCA-001	2026-06-18	Dependabot/Snyk	Apache Tika XXE	`org.apache.tika:tika-core` 2.9.2	Critical	Echte finding	Tika wordt gebruikt bij upload MIME-detectie. Directe upgrade naar 3.2.2 is getest maar blokkeert op Java 8. Upload allowlist/MIME is als compensating control aangescherpt. `06-sca-sbom-triage.md`; `bewijs/sbom-sca/dependabot-tika-critical-alert-full.png`; `bewijs/sbom-sca/sbom.cdx.json`	Niet geaccepteerd	Open: upgradepad/reviewer nodig	
SCA-002	2026-06-18	Dependabot/Snyk	OpenMRS Module Upload Zip Slip	`org.openmrs.web:openmrs-web` 2.2.0	Critical	Open risico	Repository-prodconfig beperkt module-upload exposure, maar echte runtime/exposure moet door owner worden bevestigd. `06-sca-sbom-triage.md`; `bewijs/sbom-sca/dependabot-openmrs-module-upload-zip-slip-overview.png`	Open	Open: owner-runtimecheck nodig	
SCA-003	2026-06-18	Dependabot/Snyk	OpenMRS ModuleResourcesServlet path traversal	`org.openmrs.web:openmrs-web` 2.2.0	High	Open risico	Tomcatversie en module-resource exposure zijn niet aantoonbaar in deze repository. Daarom niet als false positive sluiten. `06-sca-sbom-triage.md`; `bewijs/sbom-sca/dependabot-openmrs-module-resources-path-traversal-overview.png`	Open	Open: owner-runtimecheck nodig	

Onderdrukking in de tool zelf (bijv. een .snyk policy-bestand of het dismissen van een code scanning alert in GitHub) gebeurt pas na aftekening en verwijst in de toelichting naar het register.

Huidige status

Op dit moment zijn er nog geen scanmeldingen definitief als false positive beoordeeld. Er zijn wel CodeQL-findings geregistreerd die als echte bevinding zijn beoordeeld en opgelost.

Open scanmeldingen uit CodeQL, Dependabot, Snyk of SBOM/SCA moeten eerst worden onderzocht. Daarna kunnen ze in het register hierboven worden opgenomen als false positive, geaccepteerd restrisico, opgelost of nog open.

Herbeoordeling

Het register wordt per sprint doorgelopen. Een false positive vervalt als de onderbouwing niet meer klopt (bijvoorbeeld na een dependency-upgrade of codewijziging); de bevinding wordt dan opnieuw getriageerd.

Koppeling met NEN-7510

Dit beleid ondersteunt de maatregelen rond:

- A.8.8 Kwetsbaarheidsbeheer;
- A.8.15 Logging;
- A.8.25 Veilige ontwikkelcyclus.

Bijlage F - Gap-analyse

docs/auditrapport/security/01-gap-analyse.md

Gap-Analyse

Dit document beschrijft de gap-analyse van de OpenMRS Attachments module ten opzichte van drie specifieke beveiligingscontrols uit de NEN-7510:2024-2 normering.

1. Control A.8.3: Toegangsbeveiliging

Eis: Gebruikers mogen alleen toegang krijgen tot het netwerk en de netwerkdiensten waarvoor zij specifiek geautoriseerd zijn (Least Privilege).

Status: gedeeltelijk aanwezig

Bewijs & Analyse:

De module bouwt op het OpenMRS framework, dat op platformniveau toegangsbeveiliging afdwingt. Echter, op moduleniveau ontbreekt bij specifieke endpoints de benodigde input-validatie en autorisatiecontrole. Het belangrijkste bewijs hiervoor is te vinden in het zelfgemaakte download endpoint, dat een Path Traversal / Local File Inclusion (LFI) risico introduceert.

Bestand: AttachmentBytesResource.java (Regels 103-113)

```
@RequestMapping(value = "/download", method = RequestMethod.GET)
public void downloadFile(@RequestParam("path") String path, HttpServletResponse response) throws java.io.IOException {
    // DANGEROUS: Directly reading files from the filesystem based on user input without any access control or path
    validation.
        java.io.File file = new java.io.File(path);
        java.io.FileInputStream fis = new java.io.FileInputStream(file);
        byte[] buffer = new byte[1024];
        int bytesRead;
        while ((bytesRead = fis.read(buffer)) != -1) {
            response.getOutputStream().write(buffer, 0, bytesRead);
        }
        fis.close();
}
```

Toelichting: Omdat de "path" parameter volledig user-controlled is en er geen whitelist of expliciete privilege-check (zoals Context.requirePrivilege()) wordt toegepast, zou een gebruiker bestanden buiten de bedoelde map kunnen benaderen. Hoewel de framework-security bestaat, ontbreekt in dit specifieke endpoint de "defense-in-depth" voor toegangscontrole.

2. Control A.8.5: Authenticatie

Eis: Er moet sprake zijn van een betrouwbare verificatie van de identiteit van de gebruiker voordat toegang wordt verleend.

Status: Gedeeltelijk Aanwezig

Bewijs & Analyse:

De module bevat zelf geen actieve authenticatiemechanismen (zoals login-, token- of sessiecontroles). Dit is deels by design, aangezien de module deze verantwoordelijkheid delegeert naar het onderliggende OpenMRS Core platform.

Bestand: AttachmentResource.java

```
@Resource(name = RestConstants.VERSION_1 + "/"
    + AttachmentsConstants.ATTACHMENT_URI, supportedClass = Attachment.class, supportedOpenmrsVersions = {
        "2.2.* - 9.*" })
public class AttachmentResource extends DataDelegatingCrudResource<Attachment> implements Uploadable { ... }
```

Toelichting: De endpoints zijn gebouwd als extensie op DataDelegatingCrudResource en BaseRestController. Hierdoor vertrouwt de module passief op de overkoepelende authenticatiefilters van de OpenMRS /rest/v1/ API. Als OpenMRS globaal goed is geconfigureerd, is authenticatie afgedwongen, maar "defense-in-depth" ontbreekt in de module zelf, wat extra risico oplevert bij kwetsbaarheden zoals gevonden bij A.8.3.

3. Control A.8.15: Logging

Eis: Gebeurtenissen (zoals toegang tot patiëntgegevens, fouten en informatiebeveiligingsincidenten) moeten worden vastgelegd (gelogd) en bewaard.

Status: Gedeeltelijk aanwezig

Bewijs & Analyse:

Er is logging aanwezig om te registreren welke bestanden worden opgevraagd, wat een goede eerste stap is richting compliance, maar de manier waarop dit wordt gedaan levert een datalek van medische persoonsgegevens (PII) in de systeemlogs op.

Bestand: AttachmentsServiceImpl.java (Regels 38-43)

```
// Audit logging for regulatory compliance — records which patient's attachments are accessed
log.info("Fetching attachments for patient: id=" + patient.getId())
```

```

+ " uuid=" + patient.getUuid()
+ " name=" + patient.getPersonName()
+ " dob=" + patient.getBirthdate()
+ " identifiers=" + patient.getIdentifiers(); // PII written to application log

```

Toelichting: In bovenstaand fragment werden patiëntnaam, geboortedatum en medische identifiers als platte tekst (plaintext) in de applicatielogs geschreven. Hoewel dit voldoet aan de eis "er moet gelogd worden dat data is ingezien", is het direct in strijd met de AVG en NEN-7510 richtlijnen rondom dataminimalisatie.

Status: Deze bevinding is in de code gemitigeerd. AttachmentsServiceImpl logt nu alleen minimale technische context voor het ophalen van attachments. AttachmentsServiceImplTest controleert dat patiëntnaam, geboortedatum, interne patient-id en identifiers niet in de logtekst staan.

Daarnaast mist er audit-logging bij kritieke acties; er wordt in AttachmentBytesResource.java helemaal niets gelogd wanneer een bestand via de /download functie wordt opgehaald.

4. Geprioriteerde non-compliance lijst

Onderstaande lijst bundelt de belangrijkste afwijkingen uit de gap-analyse, pentest, SCA/SBOM-triage en auditdocumentatie. De volgorde is gebaseerd op risico voor vertrouwelijkheid, integriteit en aantoonbaarheid richting NEN-7510.

Prioriteit | Non-compliance | NEN-7510-control | Status | Vervolgactie

- 1 | Hardcoded credential-achtige waarden stonden in broncode. | A.8.5, A.8.25, A.8.28 | Opgelost | Hardcoded waarden zijn verwijderd uit `AttachmentsActivator.java`; hertestbewijs staat in `bewijs/pentest`.
- 2 | Raw path download/path traversal kon leiden tot arbitrary file read. | A.8.3, A.8.28, A.8.29 | Opgelost | UUID-downloadflow, privilegecheck en regressietests zijn toegevoegd; bewijs staat in pentest- en CodeQL-documentatie.
- 3 | File access in attachment handler had onvoldoende traversal-bescherming. | A.8.28, A.8.29 | Opgelost | Path normalization/root-check en regressietests zijn toegevoegd.
- 4 | Uploadvalidatie kon te ruim zijn bij lege allowlist of MIME mismatch. | A.8.28, A.8.29 | Opgelost | Veilige default allowlist, extensiecontrole, MIME-controle en tests zijn toegevoegd.
- 5 | Download-autorisatie was onvoldoende expliciet bewezen op moduleniveau. | A.8.3, A.8.5, A.8.29 | Gedeeltelijk opgelost | Expliciete `View Attachments` check en regressietests zijn toegevoegd; patienttoegang blijft afhankelijk van OpenMRS runtimebeleid.
- 6 | Logging bevatte te veel patient-PII of was onvoldoende veilig tegen vervuilde logregels. | A.8.15, A.8.28 | Gedeeltelijk opgelost | Logberichten zijn geminimaliseerd en getest voor onderzochte paden; volledige productie-auditlogging blijft vervolgwerk.
- 7 | Critical dependencyfinding Apache Tika XXE is nog niet definitief opgelost. | A.8.8, A.8.28, A.8.29 | Open | Java/OpenMRS upgradepad bepalen of veilige Java 8-compatibele oplossing vinden; compensating controls zijn tijdelijk toegevoegd.
- 8 | OpenMRS Core runtimealerts voor Zip Slip/path traversal zijn nog niet met productiegegevens bevestigd. | A.8.8, A.8.25, A.8.29 | Open | Owner moet runtimeversie, Tomcatversie en endpoint-exposure bevestigen.
- 9 | Maven Tests zijn ingericht maar nog niet als required check geselecteerd. | A.8.25, A.8.29 | Open door rechten | Repository-owner moet de groene Maven Tests check toevoegen aan branch/ruleset protection.
- 10 | Environment secrets en deploymentflow zijn nog niet volledig aantoonbaar ingericht. | A.8.5, A.8.25 | Open | Echte secrets pas toevoegen via GitHub Environments zodra ze beschikbaar zijn; production approval behouden.

Deze lijst is bedoeld als compact stuurdocument voor de resterende audit- en Sprint 4-acties. Details, bewijs en risicoweging staan in risk-assessment-report.md, 06-sca-sbom-triage.md, 11-traceability-matrix.md en 12-security-audit-eindrapport.md.

Digitale ondertekening

Deze PDF is bedoeld om cryptografisch te worden ondertekend. De ondertekening wordt na export toegevoegd als PDF-signature met een self-signed auditcertificaat, omdat er geen extern persoonsgebonden certificaat in de repository aanwezig is.

Signer: OpenMRS Attachments Audit

Datum: 2026-06-18

Reden: Security audit eindrapport Sprint 4

Locatie: docs/auditrapport/security/output/